

Milpa: Eco-Mercado Digital

Seguridad y Buenas Prácticas

Entregable de preclasificación — Diagramación y Seguridad

Proyecto: Milpa

Versión: 1.0

Fecha: Agosto 2026

Ficha del documento

Fecha	Revisión	Autor	Descripción
15/Ago/26	1.0	Equipo Milpa	Documento inicial: buenas prácticas, código legible, definición de 3 roles y permisos (Admin, Usuario, Auditor).

Contents

Milpa: Eco-Mercado Digital	1
Ficha del documento	2
1. Introducción	4
1.1 Propósito	4
1.2 Alcance	4
1.3 Referencias	4
2. Buenas prácticas de desarrollo	5
2.1 Arquitectura hexagonal (puertos y adaptadores)	5
2.2 Control de versiones	5
2.3 Pruebas	5
2.4 Manejo de errores	5
2.5 Seguridad por defecto	5
3. Código legible	6
3.1 Nombres que comunican intención	6
3.2 Estructura y tamaño	6
3.3 Comentarios	6
3.4 Consistencia	6
4. Roles y permisos (RBAC)	7
4.1 Modelo de roles	7
4.2 Principios del modelo	7
4.3 Matriz de permisos	7
4.3.1 Cuenta y perfil	7
4.3.2 Catálogo y marketplace	8
4.3.3 Flujo minorista	8
4.3.4 Flujo mayorista	8
4.3.5 Ofertas de liquidación	8
4.3.6 Calidad y moderación	8
4.3.7 Auditoría	8
4.4 Ciclo de vida de los roles	9
5. Resumen	9

1. Introducción

1.1 Propósito

Este documento define las buenas prácticas de desarrollo y el modelo de seguridad de Milpa, la plataforma digital de mercado agropecuario descrita en la Especificación de Requisitos de Software (Brief v2.1).

Cubre tres ejes:

- Buenas prácticas de desarrollo aplicadas al proyecto.
- Criterios de código legible.
- Definición formal de roles y permisos mediante un modelo RBAC de tres roles: **Admin**, **Usuario** y **Auditor**.

1.2 Alcance

El documento se aplica a la totalidad del sistema: API REST (Go), aplicación web (React), aplicación móvil (Flutter), base de datos PostgreSQL, caché Redis y canal de chat WebSocket.

No se incluyen aquí los requisitos funcionales de cada módulo (ver Brief v2.1), sino las políticas transversales de calidad y seguridad que los gobiernan.

1.3 Referencias

- Brief v2.1 — Milpa: Eco-Mercado Digital, Especificación de Requisitos de Software. Disponible en la documentación del proyecto en GitHub (repositorio CharFranR/Milpa, carpeta docs/, archivo brief.pdf).
- OWASP Top 10 (2021) — API Security Risks.
- Bases del Hackathon Nicaragua 2026.

2. Buenas prácticas de desarrollo

2.1 Arquitectura hexagonal (puertos y adaptadores)

El sistema se desarrolla bajo arquitectura hexagonal: el dominio del núcleo es independiente de los detalles de infraestructura (PostgreSQL, Redis, HTTP, WebSocket). Esto permite:

- Probar la lógica de negocio sin depender de servicios externos.
- Evolucionar cada capa sin reestructurar el sistema.
- Cambiar adaptadores (base de datos, caché) sin tocar el dominio.

2.2 Control de versiones

- Git con ramas por funcionalidad y pull requests como puerta de revisión.
- Commits convencionales (feat, fix, test, chore, docs) que describen el cambio con un solo verbo.
- Commits pequeños, enfocados en un único propósito (unidad de trabajo revisable).
- Nunca se suben secretos, credenciales ni datos de configuración local.

2.3 Pruebas

- Pruebas unitarias por capa: dominio (entidades), casos de uso (puertos primarios) con repositorios falsos, y adaptadores.
- Pruebas de tabla (table-driven) con casos que incluyen rutas felices, errores y bordes.
- La suite completa se ejecuta con `go test ./... -race` antes de cada PR.
- El objetivo es que las pruebas describan el comportamiento esperado, no la implementación.

2.4 Manejo de errores

- Errores de dominio tipados (ErrNotFound, ErrEmailRequired) que el adaptador traduce a códigos HTTP correctos.
- Nunca se exponen internals (stack traces, SQL, rutas de archivos) al cliente.
- Los errores esperados se manejan explícitamente; los inesperados se registran para auditoría.

2.5 Seguridad por defecto

- Contraseñas con hash bcrypt.
- Autenticación con JWT con expiración.
- Toda comunicación sobre HTTPS.
- Validación de cuerpos de petición en la API.
- CORS configurado para los orígenes permitidos.
- Protección contra SQL injection (consultas parametrizadas), XSS y CSRF.
- Registro de todas las operaciones sensibles para auditoría (RNF-02, RNF-07 del Brief).

3. Código legible

3.1 Nombres que comunican intención

- Identificadores descriptivos: el nombre de una función describe qué hace y qué devuelve.
- Evitar abreviaturas ambiguas y nombres genéricos (data, info, temp).
- Un nombre dudoso es una señal de diseño: dividir o renombrar antes de documentar con comentarios.

3.2 Estructura y tamaño

- Archivos y funciones pequeños, con una única responsabilidad.
- Organización por dominio y capa, no por tipo de archivo.
- Sin lógica duplicada: extraer a funciones o puertos compartidos.

3.3 Comentarios

- Sin comentarios muertos ni código comentado.

3.4 Consistencia

- Formato automático (gofmt) aplicado a todo el código.
- Convenciones del equipo documentadas y aplicadas en revisión de PR.
- Resultado: cualquier miembro del equipo puede leer cualquier archivo y entenderlo sin contexto previo.

4. Roles y permisos (RBAC)

4.1 Modelo de roles

Milpa define tres roles de sistema, que se asignan a la cuenta de usuario:

Rol	Descripción	Asignación
Admin	Responsable de la plataforma: gestiona usuarios, catálogos, reportes, moderación y auditoría.	Asignado al crear la cuenta (personal del equipo).
Usuario	Rol de negocio. Agrupa los tipos de cuenta del Brief: Agricultor, Comprador Minorista, Comprador Mayorista Detallista y Comprador Mayorista Corporativo. Cada tipo hereda las operaciones de su flujo comercial.	Seleccionado en el registro (RF-01). No intercambiable entre tipos.
Auditor	Acceso de solo lectura a la información de la plataforma y a los registros de auditoría. No realiza operaciones de negocio ni de moderación.	Asignado por el Admin a un usuario existente. No es un tipo de cuenta de registro.

4.2 Principios del modelo

- **Menor privilegio:** cada rol accede únicamente a las operaciones que necesita.
- **Solo lectura para auditoría:** el Auditor consulta pero nunca escribe.
- **Separación de responsabilidades:** quien opera (Usuario) no audita; quien modera (Admin) no es el mismo que registra la evidencia.
- **Registro de auditoría:** toda operación sensible queda en el log (RNF-02, RNF-07), consultable por Admin y Auditor.

4.3 Matriz de permisos

Cada celda indica la capacidad concreta del rol sobre la funcionalidad. “—” significa sin acceso. El rol Usuario agrupa los cuatro tipos de cuenta del Brief; cuando la capacidad aplica solo a un tipo de cuenta, se indica explícitamente.

4.3.1 Cuenta y perfil

Funcionalidad	Admin	Usuario	Auditor
Registro y autenticación (RF-01, RF-02)	—	Registrarse y autenticarse	—
Gestión del propio perfil (RF-03)	—	Completar y editar su perfil	—
Perfil de empresa agrícola y verificación (RF-04)	Verificar empresas y ver documentos	Agricultor: registrar empresa y subir documentos	Consultar
Asignación del rol Auditor	Asignar y revocar	—	—

4.3.2 Catálogo y marketplace

Funcionalidad	Admin	Usuario	Auditor
Catálogo de productos (RF-05)	—	Agricultor: crear, editar, activar, renovar	Consultar
Marketplace y búsqueda (RF-07, RF-09)	Consultar	Buscar, filtrar y ver productos	Consultar

4.3.3 Flujo minorista

Funcionalidad	Admin	Usuario	Auditor
Chat directo minorista ↔ agricultor (RF-08)	—	Iniciar y responder conversaciones	—

4.3.4 Flujo mayorista

Funcionalidad	Admin	Usuario	Auditor
Solicitud de abastecimiento (RF-10)	—	Mayorista: publicar, editar y cancelar	Consultar
Oferta a solicitud (RF-11)	—	Agricultor: ofertar, editar y retirar	Consultar
Evaluación y match (RF-12)	—	Mayorista: aceptar o descartar ofertas	Consultar
Ciclo de transacción (RF-12)	—	Mayorista y agricultor: confirmar o cancelar	Consultar
Chat post-match (RF-13)	—	Coordinar entrega por chat	—

4.3.5 Ofertas de liquidación

Funcionalidad	Admin	Usuario	Auditor
Oferta de liquidación (RF-14)	—	Agricultor: publicar, restringir y asignar lote	Consultar

4.3.6 Calidad y moderación

Funcionalidad	Admin	Usuario	Auditor
Calificaciones (RF-15)	—	Calificar (1 a 5 estrellas) tras transacción	Consultar
Reportes de publicaciones (RF-16)	—	Reportar publicaciones o perfiles	Consultar
Moderación (RF-16)	Aprobar, rechazar y suspender	—	Consultar
Catálogos de tipos y unidades (RF-06, RF-17)	Crear, editar y desactivar	—	Consultar
Gestión de usuarios (RF-17)	Ver, suspender, activar, asignar Auditor	—	Consultar

4.3.7 Auditoría

Funcionalidad	Admin	Usuario	Auditor
Registros de auditoría (RNF-02, RNF-07)	Consultar y exportar	—	Consultar

4.4 Ciclo de vida de los roles

- **Admin:** creado por el equipo; puede asignar el rol Auditor a cualquier usuario.
- **Usuario:** elegido al registrarse entre los cuatro tipos de cuenta; no intercambiable (RF-01).
- **Auditor:** asignado y revocado únicamente por el Admin; no se elige en el registro.
- La suspensión de un usuario por reportes confirmados (RF-16) revoca su acceso a todas las operaciones, incluidas las de su rol.

5. Resumen

Milpa aplica buenas prácticas de desarrollo (arquitectura hexagonal, commits convencionales, pruebas por capa, errores tipados, seguridad por defecto) y código legible (nombres con intención, archivos pequeños, comentarios de porqué, formato consistente). La seguridad de acceso se organiza en tres roles — Admin, Usuario y Auditor — con una matriz de permisos de menor privilegio y registro de auditoría para todas las operaciones sensibles.

El modelo de roles aquí definido es consistente con el Brief v2.1 y con el Modelo ER de la base de datos (rol auditor en la entidad users).